

Apa itu ffuf?

ffuf (**Fuzz Faster U Fool**) adalah tool fuzzing web yang sangat populer di CTF dan pentest.

Biasanya dipakai untuk:

- directory brute force
- endpoint discovery
- parameter fuzzing
- virtual host discovery
- file discovery
- API fuzzing

Tool ini jauh lebih cepat dibanding wfuzz.

Project resmi: [ffuf GitHub](#)

1. Install ffuf di Ubuntu

Cara paling mudah

```
sudo apt update
```

```
sudo apt install ffuf
```

Cek:

```
ffuf -h
```

Install versi terbaru dari GitHub

```
go install github.com/ffuf/ffuf/v2@latest
```

Pastikan \$HOME/go/bin masuk PATH.

2. Struktur Dasar ffuf

```
ffuf -u URL -w WORDLIST
```

Contoh:

```
ffuf -u http://target/FUZZ -w wordlist.txt
```

FUZZ = placeholder payload.

3. Directory Bruteforce

Contoh

```
ffuf -u http://target/FUZZ -w common.txt
```

Mencari:

- admin
- login
- backup
- uploads

4. Hide 404

Biasanya semua path menghasilkan response.

Gunakan:

```
ffuf -u http://target/FUZZ -w common.txt -fc 404
```

-fc

= filter code.

5. Contoh Output

admin [Status: 200, Size: 1234]

backup [Status: 301, Size: 0]

config.php [Status: 403, Size: 55]

Interpretasi:

- 200 → ada
- 301 → redirect
- 403 → forbidden tapi file ada

6. LFI Fuzzing

Misalnya:

/view.php?file=

Command:

```
ffuf -u "http://target/view.php?file=FUZZ" \
```

```
-w lfi.txt
```

Payload:

/etc/passwd

../../../../etc/passwd

php://filter/convert.base64-encode/resource=index.php

7. Fuzzing Extensions

Misalnya mencari:

- php
- txt
- bak

Gunakan:

```
ffuf -u http://target/indexFUZZ -w extensions.txt
```

Payload:

.php

.bak

.txt

.old

8. POST Request

```
ffuf -X POST \
```

```
-u http://target/login \
```

```
-d "username=admin&password=FUZZ" \
```

```
-w passwords.txt
```

9. Tambahkan Header

Cookie:

```
ffuf -u http://target/FUZZ \  
-H "Cookie: PHPSESSID=123" \  
-w wordlist.txt
```

Authorization:

```
ffuf -u http://target/api/FUZZ \  
-H "Authorization: Bearer TOKEN" \  
-w api.txt
```

10. Gunakan Burp Proxy

```
ffuf -x http://127.0.0.1:8080 \  
-u http://target/FUZZ \  
-w wordlist.txt
```

Cocok untuk:

- intercept
 - debugging
 - melihat response detail
-

11. Virtual Host Discovery

Kadang website punya hidden subdomain.

```
ffuf -u http://target \  
-H "Host: FUZZ.target.com" \  
-w subdomains.txt
```

12. Parameter Discovery

```
ffuf -u "http://target/index.php?FUZZ=test" \  
-w params.txt
```

Mencari parameter:

- id
 - file
 - page
 - debug
-

13. Recursive Scan

```
ffuf -u http://target/FUZZ \
```

```
-w common.txt \
```

```
-recursion
```

ffuf akan scan directory baru otomatis.

14. Filter Berdasarkan Size

Kadang semua response 200.

Gunakan:

Filter size

```
-fs 1234
```

Filter words

```
-fw 100
```

Filter lines

```
-fl 50
```

15. Multi-threading

Default sudah cepat.

Tambah thread:

```
-t 100
```

Contoh:

```
ffuf -t 100 -u http://target/FUZZ -w common.txt
```

16. Wordlist Penting

Biasanya pakai:

[SecLists GitHub](#)

Install:

```
sudo apt install seclists
```

Lokasi:

```
/usr/share/seclists/
```

Wordlist populer:

```
Discovery/Web-Content/common.txt
```

```
Discovery/Web-Content/directory-list-2.3-medium.txt
```

17. Contoh Workflow CTF

Scan directory

```
ffuf -u http://ctf.local/FUZZ \
```

```
-w common.txt \
```

```
-fc 404
```

Ketemu admin

```
admin [Status: 200]
```

Scan file di admin

```
ffuf -u http://ctf.local/admin/FUZZ \
```

```
-w raft-small-files.txt
```

Ketemu backup.zip

Download dan analisa.

18. ffuf vs wfuzz

Feature	ffuf	wfuzz
Speed	Sangat cepat	Lebih lambat
UI	Simple	Kompleks
Recursive	Ya	Terbatas
JSON output	Ya	Ya
Popular di CTF	Sangat	Masih dipakai

Sekarang mayoritas pemain CTF memakai ffuf.

19. Cheat Sheet Penting

Directory scan

```
ffuf -u http://target/FUZZ -w wordlist.txt
```

Hide 404

```
-fc 404
```

Tambah extension

```
-e .php,.txt,.bak
```

POST request

```
-X POST -d "a=FUZZ"
```

Header

```
-H "Authorization: Bearer TOKEN"
```

Proxy Burp

```
-x http://127.0.0.1:8080
```

20. Kombinasi ffuf + Burp + CTF

Workflow umum:

1. Scan endpoint dengan ffuf
2. Kirim request ke Burp
3. Analisa manual

4. Cari:

- SQLi
- XSS
- IDOR
- LFI
- SSRF

Kalau mau, saya juga bisa bantu:

- membuat lab ffuf lokal
- contoh challenge CTF untuk ffuf
- wordlist terbaik untuk CTF
- ffuf untuk API attack
- ffuf untuk JWT
- ffuf untuk parameter discovery
- ffuf untuk virtual host discovery
- automation ffuf + Burp Suite
- bypass rate limit saat fuzzing